

Fig. 2: Authentication process in GSM

(EIR) is a database that contains a list of all valid mobile equipment on the network, where each mobile station is identified by its IMEI number. The status returned in response to an IMEI query to the EIR may be white-listed, grey-listed or black-listed. The white-listed ME is allowed to connect to the network. Grey-listed means that the terminal is under observation from the network for possible problems. The black-listed terminal has either been reported stolen or is not type-approved (the correct type of terminal for a GSM network). Black-listed terminals are not allowed to connect to the network.

GSM security mechanisms

GSM standard was designed to be a secure mobile phone system with strong subscriber-authentication and over-the-air transmission encryption. The security model and algorithms were developed in secrecy and were never published. GSM system provides solutions to a few important aspects of security including:

1. Authorising network access (authentication)

2. Protecting user-identity confidentiality (use of temporary identities)

3. Protecting user-data confidentiality (use of encryption)

4. Protecting network signalling information and the SIM module, which plays an important role in GSM security

A personal identification number (PIN) code is used as a local security (network security is not involved here) for authentication of the SIM. The PIN is stored in the SIM and is asked when the mobile phone is switched on. If three faulty PIN inputs are entered, a longer personal unblocking key is asked. If ten faulty unblocking key inputs are keyed-in, the SIM gets locked.

Authentication. Since U_{im} is vulnerable to fraudulent access, it is necessary to determine whether the IMSI received from the mobile subscriber is from the SIM that was assigned this particular IMSI. For this purpose, authentication of mobile subscribers is done. It is also done to protect the network against unauthorised access. It provides a degree of protection for GSM subscribers by preventing intruders from impersonating authorised users.

A request for authentication can be initiated by the MS or the network. The authentication process involves three items of information:

Ki key. A ciphering key stored permanently only in the MS SIM and in the subscriber profile in the AuC

RAND. A random number generated within the AuC

SRES. A 'signed result' code generated in the AuC by passing the Ki and RAND through A3 algorithm

Authentication is built around this notion and Ki that reside in only two places—in AuC and in the user's SIM card. Since Ki is never transmitted, it is virtually impossible for unauthorised individuals to obtain this key to impersonate a mobile subscriber.

The AuC upon request from the MSC generates a number of security information 'triplets'—each comprising a RAND, an SRES and a Kc key (the key is generated as part of the triplet but used for encryption rather than authentication). This group of triplets is sent to and stored in the VLR associated with the MS. Each time an authorisation is requested, a new triplet is used. If all triplets held in the VLR are used, the MSC requests a new batch from the HLR/AuC using a "Send Authentication Info" message. The HLR/AuC responds with this information using a "Send Authentication Info Ack" message.

The authentication process is shown in Fig. 2. The subscriber (MS) requests network access by sending its IMSI/temporary mobile subscriber identity (TMSI) to the MSC. The IMSI is sent to the MSC only in the case of first-time entry of the MS into the network or data loss at VLR. The MSC checks whether its VLR holds a valid unused triplet. If not, new pairs are requested from the AuC.

The AuC using the IMSI extracts the subscriber's Ki. It then generates RAND and applies Ki and RAND to the authentication algorithm (A3) and cipher key-generation algorithm (A8) to produce an authentication $SRES_1$ and a Kc. The AuC then returns an authentication triplet—RAND, $SRES_1$ and Kc—to the VLR.

The MSC/VLR keeps the two parameters—Kc and $SRES_1$—for later use and sends the RAND component of the pair to the MS using an "Authentication and Ciphering Request" message. The MS reads its Ki from the SIM and applies the received RAND and Ki to A3 and A8 to produce $SRES_2$ and Kc. It saves Kc to be used when it receives the command to cipher the channel. The MS returns the generated SRES to the MSC/VLR using an "Authentication and Ciphering Response" message.